

Security+ 1.4 · Key Exchange

Mestre CyberSec · Lesson 1.4 — Key Exchange (3:39) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Diffie-Hellman: duas partes derivam a MESMA chave secreta trocando só valores PÚBLICOS — sem enviar a chave! Na TLS moderna usa-se ECDHE (efêmero): chave NOVA a cada sessão, dando Perfect Forward Secrecy (se a chave privada vazar amanhã, sessões passadas não decifram).

💡 Key Exam Highlights & Critical Concepts

- DH troca valores públicos e deriva chave privada — a chave NUNCA viaja
- Ephemeral (ECDHE) = chave por sessão — PFS
- PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas

🎯 Exam Tips & Typical CompTIA Scenarios

- 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman
- 'protects past sessions even if key leaks' = Perfect Forward Secrecy

Why is this advanced coverage required for SY0-701? Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Diffie-Hellman (DH)

An asymmetric key agreement protocol that allows two parties to derive the same shared secret over an insecure channel by exchanging only public values — the secret key is never transmitted.

 **Exam Trap:** Exam trigger 'derive a shared secret over an untrusted channel' = DH. Do NOT confuse with RSA: RSA ENCRYPTS/TRANSPORTS a key, DH AGREES/DERIVES a key.

• Perfect Forward Secrecy (PFS)

A cryptographic property guaranteeing that the compromise of a long-term private key does NOT compromise the confidentiality of past sessions, because each session used a unique ephemeral key.

 **Exam Trap:** Exam trigger 'protects past sessions even if private key leaks' = PFS. Memorize: PFS requires ephemeral keys (DHE/ECDHE); static DH does NOT provide PFS.

• Ephemeral Key (N/A)

A cryptographic key generated for a single session or transaction and then discarded, preventing past communications from being decrypted if a long-term key is later exposed.

 **Exam Trap:** Watch for 'ephemeral' on the exam — it is the single word that signals PFS. If a question offers both DH and ECDHE, ECDHE is the secure, modern choice.

• Elliptic Curve Diffie-Hellman Ephemeral (ECDHE)

The modern TLS key exchange method that uses elliptic curve cryptography with ephemeral keys for each session, providing Perfect Forward Secrecy with smaller keys and faster computation than classic DHE.

 **Exam Trap:** Exam trigger 'modern TLS key exchange with forward secrecy' = ECDHE. Distinguish from static ECDH: the trailing 'E' (Ephemeral) is what provides PFS.

• Diffie-Hellman Ephemeral (DHE)

The non-elliptic-curve variant of ephemeral Diffie-Hellman, which generates a fresh DH key pair for every session to provide Perfect Forward Secrecy, but with larger keys and higher CPU cost than ECDHE.

 **Exam Trap:** Both DHE and ECDHE provide PFS — pick ECDHE when the question specifies elliptic curve or modern performance; pick DHE only when ECC is unavailable.

• Key Agreement (N/A)

A category of cryptographic protocols where BOTH parties contribute material to derive the shared session key, as opposed to key transport where one party generates and sends the key to the other.

 **Exam Trap:** If the question asks 'what type of cryptography is Diffie-Hellman?' the answer is 'key agreement protocol', NOT 'key exchange protocol' in the strict CompTIA vocabulary — know the distinction from key transport (RSA).

• Elliptic Curve Cryptography (ECC)

Public-key cryptography based on the algebraic structure of elliptic curves over finite fields, providing equivalent security to RSA/DH with significantly smaller key sizes (e.g., 256-bit ECC $\approx$ 3072-bit RSA).

 **Exam Trap:** Exam trigger 'smaller keys with equivalent security' = ECC. Remember: ECDHE = ECC + DH + Ephemeral $\rightarrow$ modern PFS solution in TLS.

• Shared Secret (N/A)

The identical symmetric key independently computed by both parties at the end of a Diffie-Hellman exchange, derived from each side's private value combined with the other's public value.

⚠ Exam Trap: The shared secret is the OUTPUT of DH and is then used (often with a KDF like HKDF) to derive the actual symmetric session keys for encryption — don't confuse the derived secret with the final session key.

✓ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial company is updating its TLS configuration. The security team requires that if an attacker steals the web server's long-term private key next year, recorded TLS sessions from this year must remain confidential. Which key exchange mechanism should the team prioritize?

- A) Static RSA key transport
- B) Ephemeral Elliptic Curve Diffie-Hellman (ECDHE)
- C) Static Diffie-Hellman using a fixed server key
- D) Pre-shared key (PSK) authentication only

QUESTION 2 · EXAM SCENARIO

A startup is designing a messaging protocol. Two clients must establish a symmetric session key over an untrusted network without ever transmitting the session key and without previously sharing a secret. Which cryptographic technique best meets this requirement?

- A) Diffie-Hellman key exchange
- B) RSA encryption of the session key with the server's public key
- C) AES-256-GCM encryption of the session key
- D) HMAC-SHA256 key derivation

QUESTION 3 · EXAM SCENARIO

During a design review, an engineer proposes using static Diffie-Hellman with the same private value on every TLS connection to reduce CPU usage. What is the primary security drawback of this proposal?

- A) It prevents the server from using certificates.
- B) It makes the shared secret publicly visible on the network.
- C) It provides no perfect forward secrecy if the static private value is compromised.
- D) It requires a larger symmetric key than ephemeral DH.

QUESTION 4 · EXAM SCENARIO

A company deploys a custom file transfer protocol that uses unauthenticated Diffie-Hellman to agree on keys. An attacker on the same network can modify messages between the two endpoints. What is the most likely result?

- A) The attacker can perform a man-in-the-middle attack and establish separate shared secrets with each endpoint.
- B) The attacker can recover the private Diffie-Hellman values by brute force in real time.
- C) The attacker can force the endpoints to use AES instead of 3DES.
- D) The attacker can decrypt the shared secret directly because it is sent in the clear.

QUESTION 5 · EXAM SCENARIO

A vulnerability scan reports that a VPN gateway supports DHE with a 1024-bit prime. Which action best addresses the risk while preserving forward secrecy?

- A) Replace DHE with static RSA key transport.
- B) Disable all ephemeral key exchanges and use pre-shared keys.
- C) Switch from AES-GCM to CBC mode for session encryption.
- D) Increase the DHE prime size to at least 2048 bits or migrate to ECDHE with approved curves.

QUESTION 6 · EXAM SCENARIO

A mobile banking app must use TLS with forward secrecy but has limited CPU and battery. The architect wants to minimize cryptographic overhead while maintaining strong security. Which key exchange is most appropriate?

- A) ECDHE with a modern elliptic curve
- B) Static RSA key exchange with a 4096-bit key
- C) DHE with an 8192-bit prime
- D) RSA key transport with AES-256 session keys

QUESTION 7 · EXAM SCENARIO

An incident responder learns that an attacker has obtained a web server's long-term TLS private key. The server was configured with TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256. Which statement best describes the impact on previously recorded TLS sessions?

- A) All previous sessions can be decrypted because the RSA key was used for key exchange.
- B) Previous sessions can be decrypted only if AES-128 is also broken.
- C) Previous sessions that used unique ephemeral ECDHE keys remain confidential.
- D) Previous sessions are vulnerable because SHA256 hashes the session key.

QUESTION 8 · EXAM SCENARIO

A security analyst sees the cipher suite TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 in a packet capture. Which component indicates that the session can achieve perfect forward secrecy?

- A) ECDSA
- B) AES_256_GCM
- C) SHA384
- D) ECDHE

QUESTION 9 · EXAM SCENARIO

A company wants to build a VPN where both endpoints authenticate each other with digital certificates and then derive a unique symmetric key for each session. Which design best satisfies these requirements?

- A) Use ECDHE for key agreement and certificates for authentication.
- B) Use static RSA encryption for key transport and no authentication.
- C) Use AES-GCM to encrypt the Diffie-Hellman public values and rely on HMAC for authentication.
- D) Use a single pre-shared key for all sessions and rotate it annually.

QUESTION 10 · EXAM SCENARIO

Two systems complete a Diffie-Hellman exchange over the Internet. After computing the shared secret, they use it to derive symmetric session keys. Which statement correctly describes the exchange?

- A) The shared secret is sent across the network encrypted with the peers' public keys.
- B) The public values are kept secret and never transmitted.
- C) The shared secret is the same as each peer's public value.
- D) Each peer combines its own private value with the other peer's public value to compute the same shared secret.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Ephemeral Elliptic Curve Diffie-Hellman (ECDHE)

ECDHE uses an ephemeral key pair for each session, so the session key is not derivable from the server's long-term private key. Static RSA and static DH lack PFS; a static PSK-only design also does not provide per-session forward secrecy.

Question 2: Option A — Diffie-Hellman key exchange

Diffie-Hellman allows two parties to derive the same shared secret by exchanging only public values; the secret itself is never transmitted. RSA key transport sends an encrypted secret, AES and HMAC do not perform key agreement.

Question 3: Option C — It provides no perfect forward secrecy if the static private value is compromised.

Static DH reuses the same private value, so compromise of that value can allow decryption of past recorded sessions. DH does not expose the shared secret, certificates are still possible, and symmetric key size is not the main issue.

Question 4: Option A — The attacker can perform a man-in-the-middle attack and establish separate shared secrets with each endpoint.

Unauthenticated DH is vulnerable to MITM: the attacker substitutes public values and shares one secret with each side. The shared secret is not sent in the clear, and brute-forcing proper DH private values is not a real-time practical attack.

Question 5: Option D — Increase the DHE prime size to at least 2048 bits or migrate to ECDHE with approved curves.

Weak DH groups can be attacked more feasibly and are associated with Logjam-style issues. Moving to at least 2048-bit DH or approved ECDHE preserves PFS. Static RSA and static PSK do not provide the same forward secrecy, and cipher mode is unrelated.

Question 6: Option A — ECDHE with a modern elliptic curve

ECDHE provides PFS with much smaller keys and lower computational overhead than large-prime DHE, which is important on mobile devices. Static RSA key transport lacks PFS.

Question 7: Option C — Previous sessions that used unique ephemeral ECDHE keys remain confidential.

In ECDHE_RSA, RSA authenticates the handshake, but the actual key exchange uses ephemeral ECDHE keys. Compromise of the long-term RSA private key does not reveal past ephemeral secrets, so PFS protects recorded sessions.

Question 8: Option D — ECDHE

ECDHE is the ephemeral key exchange that provides PFS. ECDSA is used for authentication/signatures, AES-GCM is the symmetric cipher, and SHA384 is used in the handshake/MAC/KDF.

Question 9: Option A — Use ECDHE for key agreement and certificates for authentication.

ECDHE provides per-session key agreement with forward secrecy, while digital certificates authenticate each endpoint and help prevent MITM. Static RSA without authentication, encrypted public values, or one long-lived PSK do not meet all requirements.

Question 10: Option D — Each peer combines its own private value with the other peer's public value to compute the same shared secret.

In Diffie-Hellman, public values are exchanged openly, but each side uses its own private value and the peer's public value to compute the same shared secret. The secret itself is not transmitted, and it is not equal to a public value.